Rapport d’audit interne et d’analyse des risques SSI

Orbe Services - étude de cas simulée
Référence AUD-2026-01, version 1.0, 11 octobre 2026.
Périmètre : gestion des accès et sauvegarde/restauration.
Photographie opérationnelle : 30 septembre 2026.

Synthèse pour la direction

La revue de quatorze points de contrôle relève cinq non-conformités aux politiques internes et une observation. Huit contrôles sont satisfaisants sur l’échantillon documentaire. L’analyse retient cinq scénarios : un critique, trois élevés et un modéré. Ces niveaux utilisent le barème propre au cas et ne sont pas des notes de certification.

La priorité est le compte d’administration partagé. Il permet des opérations étendues sans attribution individuelle fiable. Deux comptes encore ouverts après départ et trois échecs consécutifs de copie distante demandent aussi une correction rapide. Le test de restauration de fichiers est réussi dans le scénario, mais ne démontre pas la reprise du service complet.

Six actions sont proposées. Leur exécution, leur validation et leur efficacité restent à démontrer. Aucun risque n’est déclaré clôturé ou accepté. Les évaluations cibles ne remplacent pas la situation actuelle.

Objet et méthode

La mission compare les politiques du dossier aux exports, aux comptes rendus et aux résultats d’essais synthétiques. Elle rapproche les mouvements RH des comptes, les échecs de copie de leur traitement et le test de restauration de sa portée attendue.

Le référentiel annoncé est ISO/IEC 27001:2022. Les rapprochements portent sur le périmètre, les rôles, les risques, l’audit interne, le suivi et les mesures sélectionnées d’accès et de sauvegarde. Les critères chiffrés sont ceux d’Orbe Services. Le texte de la norme n’est pas reproduit.

L’étude ne couvre pas le SMSI complet et ne conclut pas à sa conformité. La société, les preuves et les entretiens sont fictifs. Aucun test d’intrusion, accès à une entreprise réelle ou restauration réelle n’a été réalisé.

Contexte et échantillon

La PME fictive compte 24 salariés et dépend d’un annuaire DC-01 et d’un serveur de fichiers FS-01 pour les dossiers clients. IT travaille avec un prestataire. La direction fixe une reprise en 8 heures et une perte maximale de données de 24 heures.

Les preuves comprennent dix comptes sélectionnés, huit mouvements RH, sept nuits de sauvegarde et un essai de restauration. Les quatre départs du trimestre et la mobilité sont examinés ; les trois arrivées disposent d’une approbation préalable. Ce choix est orienté vers les points à risque et n’est pas représentatif de toute l’entreprise.

Pratiques constatées

- Les responsables des processus et les objectifs métier sont identifiés.
- Les trois nouveaux accès examinés sont validés avant activation.
- Le compte de service a une finalité et un propriétaire déclarés.
- Le dossier décrit un accès VPN avec MFA et une copie distante distincte.
- L’essai fichiers présente vingt comparaisons d’intégrité identiques et une validation métier.

Ces observations restent documentaires. Elles ne prouvent pas l’efficacité technique complète de ces moyens.

Résultats de l’audit

Constat	Résultat	Preuves principales	Suite
FE-01	Deux comptes actifs après départ	E-AC-01, E-AC-02, E-AC-03	R-01 / ACT-01
FE-02	Revue trimestrielle et mobilité non validées	E-AC-01, E-AC-02, E-AC-04	R-02 / ACT-02
FE-03	Compte privilégié partagé au quotidien	E-AC-01, E-AC-02, E-AC-04	R-03 / ACT-03
FE-04	Trois échecs distants sans ticket ni escalade	E-BK-01, E-BK-02	R-04 / ACT-04
FE-05	Essai ne couvrant pas l’annuaire et le service	E-BK-01, E-BK-03	R-05 / ACT-05
FE-06	Suivi de direction peu consolidé, observation	E-GOV-01, E-AC-04, E-BK-03	Suivi transversal / ACT-06

Les cinq premiers constats sont des non-conformités internes. FE-06 est une observation : aucun format unique de tableau de bord n’est imposé dans la note de responsabilités. Les causes issues des entretiens doivent être confirmées lors du traitement.

Risques et ordre de traitement

Risque	V	I	Score actuel	Niveau	Score cible conditionnel
R-03 : privilèges non attribuables	3	4	12	Critique	4, modéré
R-01 : accès après départ	3	3	9	Élevé	3, faible
R-04 : copie distante trop ancienne	3	3	9	Élevé	3, faible
R-05 : reprise du service non démontrée	2	4	8	Élevé	4, modéré
R-02 : droits excessifs non détectés	2	3	6	Modéré	3, faible

Les notes actuelles tiennent compte des mesures existantes. Les cibles supposent les actions réalisées et efficaces. Les conséquences restent des scénarios : aucune fuite, compromission ou perte réelle n’est déduite du dossier.

Actions proposées

Action	Résultat attendu	Responsable	Échéance
ACT-01	Retirer les accès restants et fiabiliser les départs	IT	12 octobre
ACT-03	Passer à des comptes administratifs individuels	IT	16 octobre
ACT-04	Reprendre la copie distante et tester l’alerte	IT	14 octobre
ACT-05	Exercer la restauration du service complet	IT	30 octobre
ACT-02	Valider la revue et les droits de transition	Opérations	23 octobre
ACT-06	Consolider les actions et les décisions	Administratif	23 octobre

Les retraits de comptes peuvent être lancés immédiatement. La migration administrative dépend du prestataire et doit contrôler les dépendances avant retrait du compte partagé. L’exercice de restauration doit se dérouler dans un environnement isolé.

Vérification et décision

La revue proposée du 30 novembre doit examiner les exports après correction, les validations métier, les journaux individuels, les tickets de copie et le rapport d’exercice. Le test complet doit mesurer la reprise de 8 heures et l’âge du point restauré, limité à 24 heures. Les 37 minutes de l’essai fichiers ne constituent pas cette mesure.

Le responsable de chaque risque valide la situation métier. La direction décide des moyens, des exceptions et de l’acceptation des risques restants. Les cibles de R-03 et R-05 restent modérées : leur acceptation doit être motivée, même si les actions sont efficaces.

Conclusion

La maîtrise est inégale sur les deux processus étudiés. Les règles existent et plusieurs opérations sont documentées, mais les exceptions ne sont pas suffisamment traitées. Les cinq non-conformités internes restent ouvertes. La priorité est de corriger les accès persistants, les privilèges partagés et les copies distantes, puis de démontrer la reprise complète et la tenue des revues.

Le README donne accès aux preuves, aux fiches d’écart, aux justifications des risques, au détail des actions et au registre Excel.

Références

ISO/IEC 27001:2022, notice IEC et note ISO/IEC JTC 1/SC 27 sur la SoA. Consultation le 11 octobre 2026. Les références orientent la démarche ; les preuves, règles et notes de risque sont celles du cas fictif.